BULUT BİLİŞİMİ VE SİBER GÜVENLİK

Kuryeplan
Güvenlik ve Altyapı Raporu

Kurye Çıkış Saati Planlayıcı · Uygulama, veri hattı ve container güvenliği

Öğrenci	Oğuzhan Sapmaz
Öğrenci no	2516016021
Ürün canlı adresi	https://kurye-cikis-saati-planlayici.vercel.app/
GitHub deposu	https://github.com/oguzhansapmaz/kurye-cikis-saati-planlayici
Rapor durumu	TASLAK — cloud deployment and evidence pending

Yönetici özeti

Kuryeplan; teslimat hedef saatinden geriye doğru hazırlık başlangıcını ve en geç çıkışı hesaplayan, ayrıca İstanbul şehir geneli tarihsel trafik indeksini zaman serisi ve hafta günü × saat ısı haritası ile göstermeyi amaçlayan statik web ürünüdür. Arayüz Vercel üzerinde yayımlanmıştır. GitHub Actions içinde Gitleaks, root olmayan container, salt okunur çalışma testi ve kritik zafiyette duracak Trivy kapısı yapılandırılmıştır.

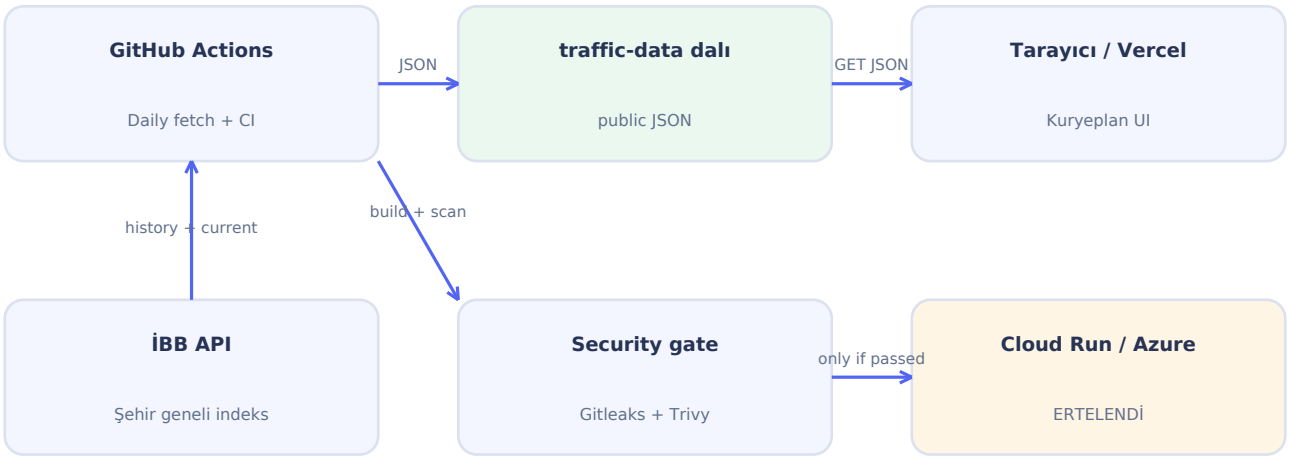
> Önemli durum notu
> Bulut sağlayıcısı doğrulaması / ödeme engeli nedeniyle Azure Container Apps veya Google Cloud Run dağıtımı kullanıcı isteğiyle şimdilik ertelendi. Bu yüzden bütçe alarmı, servis logları, izleme alarmı ve canlı bulut URL'si henüz kanıtlanmamıştır. Bu PDF final raporu değil, gerçek kanıtlarla tamamlanacak taslaktır.

Kapsam

Bu rapor; uygulama arayüzü, İBB trafik JSON veri hattı, static hosting güvenlik başlıkları, container sertleştirme ve CI güvenlik kapısını belgelendirir. Gerçek İBB veri akışı, canlı ZAP raporları, baseline Trivy JSON, kullanıcı testleri, Lighthouse sonucu ve cloud ölçümleri üretildikten sonra sonuç bölümleri güncellenmelidir.

1. Mimari ve veri akışı

Statik arayüz Vercel üzerinden HTTPS ile sunulur. Günlük GitHub Actions işi, İBB'nin saatlik tarihsel indeksini ve kısa aralıklı indeks uç noktasını çağırır, gözlemleri doğrular, JSON dosyasını atomik olarak üretir ve yalnız `traffic-data` dalına yazar. Tarayıcı bu anonim ve herkese açık JSON dosyasını raw.githubusercontent.com üzerinden çeker; böylece ana dal koruması ile veri güncellemesi ayrılabilir ve Vercel her gün yeniden build olmak zorunda kalmaz. İlk veri çekimi başarısızsa arayüz uydurma değer göstermez.



Public UI + data branch ayrıdır; bulut dağıtımı bu sürümde uygulanmadı.

Güven sınırları

Sınır	Tanım / koruma
Tarayıcı	Plan hesabı ve yerel kayıt; sunucu tarafında sipariş saklama yok.
İBB → GitHub Actions	API anahtarı yok; timeout ve 8 MB yanıt limiti; gözlem indeksi 0–100 aralığında; geçersiz history önceki dosyayı bozmaz.
Main repository / CI	Gitleaks ve Trivy gate; `permissions` en az yetki; secret/credential repoya konmaz.
Vercel / public data	CSP sadece gereken public JSON domaini ve OSM frame kaynağına izin verir. Gerçek header skoru online taramadan sonra kaydedilecek.
Container / cloud	UID/GID 101, salt-okunur runtime ve Trivy gate yapılandırıldı. Cloud deployment ertelendi.

Kaynak verinin coğrafi kapsamı

İBB endpoint'i şehir geneli trafik indeksi sunar; ilçelere veya yol segmentlerine ayrıştırılmış değildir. İlçe seçimi plan senaryosunu anlatır, gerçek rota süresini ölçmez. UI bu kısıtlamayı kullanıcıya açıklamalıdır. Veri lisansının ve tam atıf şartının güncel portal kaydından insan tarafından doğrulanması gerekir.

2. Tehdit modeli — STRIDE

Puanlama yaklaşımı: başlangıç riski = olasılık (1–5) × etki (1–5). Kalan risk metinsel değerlendirmedir; kurum içi formal risk metodolojisi değildir. Önlemler uygulanmış olsa bile kanıtı alınmayan konular “doğrulandı” sayılmaz.

ID	STRIDE	Tehdit	Önlem	Risk	Kalan	Açık kanıt
S1	Spoofing	CI yetkisinin kötüye kullanılması	Workflow permissions + branch review	10	Orta	Branch protection henüz kanıtlanmadı
S2	Tampering	Kaynak kod/Dockerfile kötü amaçlı değişir	PR review, Gitleaks, Trivy	15	Orta	Branch protection/screenshot gerekli
S3	Repudiation	Plan kararının olay kaydı yok	Yöntem notu; ileride merkezi log	9	Orta	Merkezi app logu yok
S4	Information disclosure	Gerçek kurye/sipariş verisi paylaşılır	Gerçek veri kullanmama, localStorage notu, secret scan	12	Orta	KVKK kullanıcı bilgilendirmesi sınırlı
S5	Denial of service	Yüksek trafik statik hizmeti zorlar	Cloud instance limitleri + alarm (tasarım)	8	Düşük-Orta	Cloud hizmeti kurulmadı
S6	Elevation of privilege	Container root olarak çalışır	USER 101:101, id/inspect, capability drop	15	Düşük	CI önceki çalışmada geçti; patch sonrası tekrar
S7	Elevation of privilege	Container kaçışı/host etkisi	Non-root, read-only, no-new-privileges, cap-drop	10	Orta	Cloud runtime testleri yok
S8	Tampering	Eski/zafiyetli imaj yayımlanır	Trivy CRITICAL gate; baseline comparison	20	Orta	İki JSON ve sayılar bekleniyor
S9	Information disclosure	HTTP veya eksik güvenlik başlıkları	HTTPS, HSTS, CSP, nosniff, Referrer-Policy	12	Orta	ZAP/header scan bekleniyor
S10	Tampering / DoS	Yanlış giriş yanlış plan oluşturur	Aralık/doğrulama ve tahmin uyarısı	9	Düşük	Browser/user tests bekleniyor
S11	Information disclosure	Secret CI loglarına yazılır	Gitleaks; logda env value yazdırmama	10	Orta	Run evidence güncellenmeli
S12	Repudiation	Yapılmayan testler başarılı raporlanır	Evidence register, eksik durumları dürüst işaretleme	12	Düşük	Rapor final değil

Kişisel karttaki birincil tehdit

Container’ın root olarak ve zafiyetli taban imajıyla çalışmasıdır. Kontrol zinciri: küçük unprivileged NGINX taban imajı, `USER 101:101`, read-only dosya sistemi, `no-new-privileges`, tüm Linux capability’lerinin düşürülmesi ve Trivy CRITICAL gate. İlk taramada `brotli-libs` ile ilgili kritik bulgu gözlendi ve image build sırasında paket yükseltmesi eklendi. Kullanıcının paylaştığı daha sonraki Actions görüntüsünde bu gate’in geçtiği görüldü; güncel trafik dashboard patch’i ana dala gönderildikten sonra yeniden doğrulanmalı.

3. Container ve CI/CD kontrolleri

Dockerfile üretim imajını `nginxinc/nginx-unprivileged:stable-alpine` üzerinden kurar. İmaj konfigürasyonunda UID/GID `101:101` hedeflenir. NGINX 8080 portunu dinler. Runtime smoke test `--read-only`, `/tmp` için sınırlı tmpfs, `--security-opt no-new-privileges` ve `--cap-drop ALL` ile yapılır.

Kontrol	Kod/konfigürasyon	Kanıt durumu
Root olmayan kullanıcı	Dockerfile `USER 101:101`; workflow image inspect kontrolü	Kullanıcının paylaştığı önceki Actions görüntüsünde geçti; güncel koddan sonra yeniden çalıştır.
Salt okunur çalışma	Workflow `docker run --read-only`, tmpfs `/tmp`, cap-drop	Önceki Action run görüntüsü olumlu; güncel patch sonrası yeni run bekleniyor.
Kritik zafiyet kapısı	`aquasecurity/trivy-action@v0.36.0`, `severity: CRITICAL`, `exit-code: 1`	Önceki kritik Brotli düzeltmesi sonrası run görüntüsü geçti; tam JSON artifactinden sayı alınmalı.
Secret taraması	Gitleaks action; `main` geçmişini tarar	Son paylaşılan successful run görüntüsünde `No leaks detected`; yeni patch push sonrası tekrar kontrol.
Dependabot	`.github/dependabot.yml`	Repo ayarları ve PR davranışı gerçek GitHub UI'ında kontrol edilmeli.
Veri iş akışı	`.github/workflows/traffic-data.yml` günlük schedule + manual run	İlk gerçek IBB çekimi ve `traffic-data` branch publish henüz yapılmadı.

Güvenli release ilkesi

Cloud release işi yalnızca Gitleaks ve hardened build/Trivy job'ları başarıyla tamamlandığında çalışacak şekilde tasarlanmıştır. Bu sürümde GCP kimlik doğrulaması veya Azure kurulumu yoktur; GitHub Actions'taki `Deploy the already-scanned image` adımının atlanması beklenen bir sonuçtur. Bu adım geçildi veya servis yayımlandı diye raporlanmamalıdır.

Kritik bulgu davranışı

Trivy kritik bulgu bulursa CI başarısız olur ve release adımı çalışmaz. Bilerek eski/root çalışan `Dockerfile.baseline` yalnızca izole BEFORE imajı taraması içindir; bu imaj asla internete yayımlanmamalıdır. Rapor, before/after karşılaştırmasını yalnız gerçek Trivy JSON artifact'lerinden türetmelidir.

4. Web güvenliği ve ZAP testi

Statik yayın için `vercel.json`, container yayını için `nginx/default.conf` içinde güvenlik başlıkları tanımlanmıştır. CSP dışarıdan script çalıştırmaya izin vermez; gerektiği kadar OSM iframe'i ve public traffic JSON bağlantısı tanımlıdır. HSTS, nosniff, Referrer-Policy, Permissions-Policy, frame koruması ve Cross-Origin-Resource-Policy başlıkları yapılandırılır.

Başlık	Amaç / mevcut yapılandırma	Canlı kanıt
Content-Security-Policy	`default-src self`; `script-src self`; `unsafe-inline/eval` yok; OSM frame + raw GitHub JSON için gerekli allowlist	Online header check / ZAP raporu gerekli
Strict-Transport-Security	1 yıl, `includeSubDomains`	HTTPS yanıtında kontrol et
X-Content-Type-Options	`nosniff`	curl / browser sonucu gerekli
Referrer-Policy	`strict-origin-when-cross-origin`	curl / browser sonucu gerekli
Permissions-Policy	camera, microphone, geolocation kapalı	curl / browser sonucu gerekli
X-Frame-Options	`DENY`; CSP frame-ancestors `none`	curl / ZAP sonucu gerekli
security.txt	`/.well-known/security.txt` plain text teknik uç noktası	Canlı `200` ve gövde screenshot gerekli

OWASP ZAP baseline

`.github/workflows/zap-baseline.yml` yalnızca bu ürünün kendi Vercel URL'sinde pasif baseline taraması yapmak üzere tanımlanmıştır. Manuel dispatch input'u `before` veya `after` etiketi seçer ve her sonuç ayrı artifact olarak saklanır. Bu rapor hazırlanırken gerçek ZAP BEFORE/AFTER artifact'leri alınmadı; dolayısıyla alert sayıları veya bir ZAP notu iddia edilmemektedir.

> Önemli: `/.well-known/security.txt` düz metin görünmesi gereken makine-okunabilir bir dosyadır. Normal sayfada görünür "security.txt dosyası" butonu bulunmamalıdır. İnsan tarafından okunabilir `/security` sayfası ayrı HTML arayüzüdür.

Eksik canlı ölçümler

Mozilla Observatory ≥ B+ ve securityheaders.com ≥ A hedefleri henüz ölçülmüş değildir. Bu sonuçların ekran görüntüsü online hizmetlerde gerçek tarama yapıldıktan sonra eklenmelidir. HTTPS/HSTS/CSP konfigürasyonu tek başına bir puan garantisi vermez.

5. Testler ve ürün davranışı

Bu rapor taslağının hazırlanması sırasında çalışma klasöründeki Python veri hattı ve UI kontrat testleri çalıştırıldı. JavaScript dosyaları `node --check` üzerinden sözdizimi kontrolünden geçti. Bu kontroller kod seviyesindedir; gerçek İBB endpoint çağrısı, browser kullanıcı testi veya Windows Docker build çalıştırması değildir.

Test	Sonuç	Yorum
Python unittest — veri hattı	5 test geçti	Normalizasyon, sıralama, 24+ gözlem, günlük snapshot ve saatlik fallback
Python unittest — UI kontratı	4 test geçti	Gerekli dashboard ID'leri, yerel linkler, başlangıçta sahte veri yokluğu, CSP allowlist
JavaScript syntax	3 dosya geçti	`app.js`, `map.js`, `traffic-dashboard.js`; runtime tarayıcı testi yerine geçmez
İBB canlı fetch	Yapılmadı	Bu çalışma ortamında dış ağ erişimiyle kaynak çağrısı doğrulanmadı; GitHub Actions manuel run gerekir
Docker build / local readonly	Bu ortamda yapılmadı	Docker CLI yok; sonraki başarılı GitHub Actions run ya da yerel Docker log'u eklenmeli
User testing / Lighthouse	Yapılmadı	2 kişi × 3 görev; Lighthouse mobile sonucu ve önce/sonra görseli bekleniyor

Veri hattı hata davranışı

Saatlik tarihsel endpoint zorunludur ve en az 24 normalize edilmiş gözlem beklenir. Yanıt JSON olarak parse edilemiyorsa, alan isimleri tanınmıyorsa veya kayıtlar doğrulamadan geçmiyorsa script başarısız olur ve önceki `data/traffic.json` dosyasını atomik yazma yoluna sokmaz. Kısa aralıklı endpoint başarısız ama history geçerliyse çıkış `partial` olarak etiketlenir, son hourly değeri gösterilir ve uyarı üretilir. Tarayıcı da önce `traffic-data` dalındaki JSON'u, ardından deploy edilmiş JSON'u ve son olarak kendi localStorage önbelleğini dener.

Kullanıcı testinde kullanılması gereken görevler

1) Son teslim saatine göre en geç çıkışı hesapla. 2) Belirli bir hafta günü için daha düşük tarihsel indeksli çıkış saatini bul. 3) Grafiği tabloya çevir, bir indeksi sırala ve değerini açıkla. Her kişi için gerçek tarih/saat, süre, başarı, takıldığı adım ve değişiklik önerisi `docs/user-test-template.csv` dosyasına yazılmalıdır. Bu raporda katılımcı sonucu uydurulmamıştır.

6. İşletim, kalan riskler ve teslim durumu

Bulut sağlayıcısı hesabı kurulum ve ödeme/kart engelleri nedeniyle kullanıcı tarafından ertelendi. Ödevin kişisel kartı Azure Container Apps veya Google Cloud Run istiyor; alternatif platform kullanmadan önce öğretim elemanının onayı alınmalıdır. Bu sebeple aşağıdaki live cloud kontrolleri gerçekleştirilmiş değildir.

Madde	Mevcut gerçek durum
Bulut URL / TLS	Cloud Run veya Azure Container Apps hizmeti kurulmadı; kullanıcı tarafından hocayla görüşülecek.
IaC apply	Terraform dosyası taslaktır; `plan/apply` çıktısı ve kaynak oluşumu kanıtı yok.
Log ve alarm	Cloud Logging / alarm kuralı kurulmadı; gerçek ekran görüntüsü yok.
Bütçe alarmı	Cloud billing henüz açılmadı; alarm yok. Maliyet sıfır varsayılmamalıdır.
ZAP before/after	İki gerçek artifact henüz alınmadı; uyarı sayısı bildirilmemeli.
Trivy before JSON	Baseline workflow henüz çalıştırılmadı; gerçek kritik sayısı bilinmiyor.
Trivy after JSON	Önceki Actions screenshot gate'in geçtiğini gösterdi; güncel traffic-data patch sonrası yeni run ve JSON indirme gerekir.
Trafik veri akışı	Manual workflow çalıştırılıp `traffic-data` dalındaki JSON doğrulanmalı; canlı veriyi ilk kez almadan UI tam görünmüş sayılmaz.
Portföy vaka / demo	Case study, demo script ve tasarım kararı dosyaları hazır; siteye yayın, video kaydı ve Lighthouse kanıtı bekleniyor.
Kullanıcı testi	2 katılımcı × 3 görev gerçek ölçümleri bekleniyor.
Branch protection / 4 gün commits	Main protection ve direkt push kapatma ayarları kanıtlanmalı. Commit geçmişi gerçek zamanlı olmalı; tarih/commit sayısı uydurulmamalı.
Lisans	İBB portal lisansı/atıf şartı doğrulanmalı.

Olay müdahalesi

`docs/incident-response-runbook.md` taslağı; şüpheli anahtar tespitinde kapsamı durdurma, anahtarı iptal/yenileme, GitHub Secret geçmişini inceleme, etkilenmiş logları koruma, kullanıcı/öğretim elemanına bildirme adımlarını içerir. Gerçek anahtar hiçbir zaman issue, screenshot, commit veya rapor PDF'sine eklenmemelidir.

Sonuç

Kuryeplan arayüzü Vercel'de yayımlandı ve GitHub güvenlik CI kapısının daha önceki çalıştırması kullanıcı ekran görüntüsünde Gitleaks ile non-root/read-only/Trivy adımlarını başarılı göstermiştir. Güncel trafik veri özellikleri ve yeni branch data workflow'u eklendikten sonra CI yeniden koşmalı; ilk gerçek İBB veri çekimi, ZAP/Trivy artifact'leri, testler ve güvenlik hizmeti kanıtları tamamlanmalıdır. Cloud yayını bu taslakta açıkça ertelenmiştir. Bu belge bu nedenle final/onaylı güvenlik raporu değil, takip edilecek kanıt planıdır.